

सूचना सुरक्षा, साइबर सुरक्षा एवं गोपनीयता
संरक्षण — आईटी सुरक्षा अनुरूपता आंकलन
निकाय के कार्मिकों की दक्षता हेतु अपेक्षाएँ

भाग 3 ISO/IEC 15408 श्रृंखला एवं
ISO/IEC 18045 के अनुसार मूल्यांकनकर्ताओं और
समीक्षकों के लिए ज्ञान एवं कौशल अपेक्षाएँ

(पहला पुनरीक्षण)

Information Security, Cybersecurity
and Privacy Protection —
Requirements for the Competence
of IT Security Conformance
Assessment Body Personnel
Part 3 Knowledge and Skills
Requirements for Evaluators and
Reviewers According to the
ISO/IEC 15408 Series and ISO/IEC 18045
(First Revision)

ICS 35.030

© BIS 2026

© ISO/IEC 2025

Follow us @



भारतीय मानक ब्यूरो

BUREAU OF INDIAN STANDARDS

मानक भवन, 9 बहादुर शाह ज़फर मार्ग, नई दिल्ली - 110002

MANAK BHAVAN, 9 BAHADUR SHAH ZAFAR MARG
NEW DELHI - 110002

www.bis.gov.in www.standardsbis.in

June 2026

Price Group 14

NATIONAL FOREWORD

This Indian Standard (Part 3) (First Revision) which is identical to 'ISO/IEC 19896-3 : 2025 Information security, cybersecurity and privacy protection — Requirements for the competence of IT security conformance assessment body personnel Part 3: Knowledge and skills requirements for evaluators and reviewers according to the ISO/IEC 15408 series and ISO/IEC 18045' issued by the International Organization Standardization (ISO) and International Electrotechnical Commission (IEC) was adopted by the Bureau of Indian Standards (BIS) on the recommendations of the Information Systems Security and Privacy Sectional Committee and approval of the Electronics and Information Technology Division Council.

This standard is published in several parts. The other parts in this series are:

Part 1 Introduction, concepts and general requirements

Part 2 Knowledge, skills and effectiveness requirements for ISO/IEC 19790 testers

This standard was first published in 2020 and was identical with ISO/IEC 19896-3 : 2018. This revision has been brought out to align it with the latest version of ISO/IEC 19896-3 : 2025.

In this revision the following major changes have been incorporated:

- a) completely reworked the requirements for evaluators, including restructuring of the content; and
- b) added requirements for personnel reviewing IT security conformance assessment activities.

The text of ISO/IEC standard has been approved as suitable for publication as an Indian Standard without deviations. Certain conventions and terminologies are, however, not identical to those used in Indian Standards. Attention is particularly drawn to the following:

- a) Wherever the words 'International Standard' appear referring to this standard, they should be read as 'Indian Standard'; and
- b) Comma (,) has been used as a decimal marker while in Indian Standards, the current practice is to use a point (.) as the decimal marker.

In this adopted standard, reference appears to certain International Standards for which Indian Standards also exist. The corresponding Indian Standards, which are to be substituted in their respective places, are listed below along with their degree of equivalence for the editions indicated. For dated references, only the edition cited applies. For undated references, the latest edition of the referenced document (including any amendments) applies:

<i>International Standards</i>	<i>Corresponding Indian Standard</i>	<i>Degree of Equivalence</i>
ISO/IEC 19896-1 Information security, cybersecurity and privacy protection — Requirements for the competence of IT security conformance assessment body personnel — Part 1: Introduction and concepts	IS/ISO/IEC 19896-1 : 2025 Information security, cybersecurity and privacy protection — Requirements for the competence of IT security conformance assessment body personnel: Part 1 Overview and concepts (<i>first revision</i>)	Identical

([*Continued on third cover*](#))

Contents

Page

Introduction	iv
1 Scope	1
2 Normative references	1
3 Terms, definitions and abbreviated terms	2
3.1 Terms and definitions	2
3.2 Abbreviated terms	2
4 Knowledge	2
4.1 Knowledge required for evaluators	2
4.1.1 General	2
4.1.2 Knowledge of the ISO/IEC 15408 series and ISO/IEC 18045	3
4.1.3 Knowledge of the assurance paradigm	5
4.1.4 Knowledge of information security	6
4.1.5 Knowledge of the technology	7
4.2 Knowledge required for reviewers	8
4.2.1 General	8
4.2.2 Knowledge of the ISO/IEC 15408 series and ISO/IEC 18045	9
4.2.3 Knowledge of the assurance paradigm	10
4.2.4 Knowledge of information security	12
4.2.5 Knowledge of technology	13
5 Skills	14
5.1 Skills required for evaluators	14
5.1.1 General	14
5.1.2 Basic evaluation skills	14
5.1.3 Core evaluation skills regarding ISO/IEC 15408-3 and ISO/IEC 18045	15
5.1.4 Skills required for specific security assurance classes	16
5.1.5 Skills required for specific security functional requirement classes	17
5.1.6 Skills required for specific technology	17
5.2 Skill required for reviewers	17
5.2.1 Basic review skills	17
5.2.2 Core review skills regarding ISO/IEC 15408-3 and ISO/IEC 18045	18
5.2.3 Skills required for specific security assurance classes	18
5.2.4 Skills required for specific security functional requirement classes	19
5.2.5 Skills required for specific technology	19
Annex A (informative) Technology types: knowledge and skills	20
Annex B (informative) Examples of knowledge and skills required for evaluating security assurance requirement classes	27
Annex C (informative) Examples of knowledge required for evaluating security functional requirement classes	40
Bibliography	44

Introduction

The ISO/IEC 15408 series permits comparability between the results of independent security evaluations. It does so by providing a common set of requirements for the security functionality of information technology (IT) products and for assurance measures applied to these IT products during a security evaluation. Many review and evaluation schemes as well as review bodies have been developed using the ISO/IEC 15408 series and ISO/IEC 18045 as a basis, which permits comparability between the results of evaluation projects.

The evaluation process usually relies on both pre-defined tests/methods for a type of TOE, and TOE-specific tests/methods that are defined for a given implementation of the TOE. Hence, the competence of the individual evaluators, who are expected not only to apply pre-defined tests/methods but to define and run TOE-specific tests/methods, is key to ensuring the comparability and repeatability of evaluation results which is the foundation for mutual recognition.

This document establishes a baseline for the minimum competence of ISO/IEC 15408 series evaluators and reviewers to ensure harmonized requirements for training ISO/IEC 15408 evaluators and reviewers. It provides specialized requirements for individuals performing IT product security evaluations and reviews to demonstrate their competence according to the ISO/IEC 15408 series and ISO/IEC 18045. ISO/IEC 15408-1 describes the general framework for competences including the various elements thereof: knowledge, skills, experience and education. This document covers knowledge and skills, especially in the following areas.

- Information security
 - Knowledge: information security principles, information security properties, information security threats and vulnerabilities.
 - Skills: understanding information security requirements, the context and the scope of evaluation.
- Information security evaluation
 - Knowledge: knowledge of the ISO/IEC 15408 series and ISO/IEC 18045, laboratory management system.
 - Skills: Basic evaluation skills, core evaluation skills, skills required when evaluating specific security assurance classes, skills required when evaluating specific security functional requirements classes.
- Information systems architecture
 - Knowledge: technology being evaluated.
 - Skills: understanding the interaction of security components and information.
- Information security testing
 - Knowledge: information security testing techniques, information security testing tools, product development lifecycle, test types.
 - Skills: creating and managing an information security test plan, designing information security tests, preparing and conducting information security tests.

The audience for this document includes testing laboratory accreditation bodies, organizations implementing evaluation schemes, laboratories, evaluators and organizations offering professional credentialing.

*Indian Standard***INFORMATION SECURITY, CYBERSECURITY AND PRIVACY
PROTECTION — REQUIREMENTS FOR THE COMPETENCE OF IT
SECURITY CONFORMANCE ASSESSMENT BODY PERSONNEL****PART 3 KNOWLEDGE AND SKILLS REQUIREMENTS FOR
EVALUATORS AND REVIEWERS ACCORDING TO THE
ISO/IEC 15408 SERIES AND ISO/IEC 18045***(First Revision)***1 Scope**

This document provides the specialized requirements for individuals to demonstrate competence in performing IT product security evaluations and reviews according to the ISO/IEC 15408 series and ISO/IEC 18045.

NOTE It is possible that evaluators and testers belong to bodies operating under ISO/IEC 17025 and reviewers belong to bodies operating under ISO/IEC 17065.

2 Normative references

The following documents are referred to in the text in such a way that some or all of their content constitutes requirements of this document. For dated references, only the edition cited applies. For undated references, the latest edition of the referenced document (including any amendments) applies.

ISO/IEC 19896-1, *Information security, cybersecurity and privacy protection — Requirements for the competence of IT security conformance assessment body personnel — Part 1: Introduction and concepts*

ISO/IEC 15408-1:—¹⁾, *Information security, cybersecurity and privacy protection — Evaluation criteria for IT security — Part 1: Introduction and general model*

ISO/IEC 15408-2:—²⁾, *Information security, cybersecurity and privacy protection — Evaluation criteria for IT security — Part 2: Security functional components*

ISO/IEC 15408-3:—³⁾, *Information security, cybersecurity and privacy protection — Evaluation criteria for IT security — Part 3: Security assurance components*

ISO/IEC 15408-4, *Information security, cybersecurity and privacy protection — Evaluation criteria for IT security — Part 4: Framework for the specification of evaluation methods and activities*

ISO/IEC 15408-5, *Information security, cybersecurity and privacy protection — Evaluation criteria for IT security — Part 5: Pre-defined packages of security requirements*

ISO/IEC 18045:—⁴⁾, *Information security, cybersecurity and privacy protection — Evaluation criteria for IT security — Methodology for IT security evaluation*

1) Under preparation. Stage at the time of publication: ISO/IEC FDIS 15408-1:2025.

2) Under preparation. Stage at the time of publication: ISO/IEC DIS 15408-2:2025.

3) Under preparation. Stage at the time of publication: ISO/IEC DIS 15408-3:2025.

4) Under preparation. Stage at the time of publication: ISO/IEC FDIS 18045:2025.

3 Terms, definitions and abbreviated terms

For the purposes of this document, the terms and definitions given in ISO/IEC 19896-1, ISO/IEC 15408-1, ISO/IEC 15408-2, ISO/IEC 15408-3, ISO/IEC 18045 and the following apply.

ISO and IEC maintain terminology databases for use in standardization at the following addresses:

- ISO Online browsing platform: available at <https://www.iso.org/obp>
- IEC Electropedia: available at <https://www.electropedia.org/>

3.1 Terms and definitions

3.1.1

supporting document

document that specifies the use of the Common Criteria (CC) or common methodology for information technology security evaluation (CEM) in a particular field or domain of technology

Note 1 to entry: Such a document can be either required or recommended, and generally specifies harmonized interpretations of the CC and CEM where deemed necessary and/or useful.

3.1.2

technical domain

family of information technology (IT) products that require specific technical competencies, especially with regard to the vulnerability analysis, requiring a common understanding of the attack potential for performing the evaluation

3.2 Abbreviated terms

CC	Common Criteria
CEM	common evaluation methodology
cPP	collaborative protection profile
ETR	evaluation technical report
IC	integrated circuit
IT	information technology
PP	protection profile
ST	security target
TSF	TOE security functionality
TSFI	TOE security functionality interface
TOE	target of evaluation

4 Knowledge

4.1 Knowledge required for evaluators

4.1.1 General

[4.1.2](#) to [4.1.5](#) address the knowledge that is required to evaluate according to the ISO/IEC 15408 series and ISO/IEC 18045.

Some knowledge is required for every evaluator independent of their specific task, while other knowledge is required only depending on the specific evaluation task and the TOE to which the evaluator is assigned.

NOTE Previous experience in tasks related to the use of the ISO/IEC 15408 series and its related documents including, but not limited to, performing related work such as review, consultancy, product development, research and specification of requirements, can contribute to the elements of knowledge that are required for competence.

4.1.2 Knowledge of the ISO/IEC 15408 series and ISO/IEC 18045

4.1.2.1 Generic knowledge of the ISO/IEC 15408 series and ISO/IEC 15408 18045

Every evaluator's knowledge shall include:

- a) the terms and definitions defined in ISO/IEC 15408-1:—⁵⁾, Clause 3; ISO/IEC 15408-2:—⁶⁾, Clause 3; and ISO/IEC 15408-3:—⁷⁾, Clause 3;
- b) the terms and definitions defined in ISO/IEC 18045:—,⁸⁾ Clause 3; and
- c) the context for evaluations according to the ISO/IEC 15408 series.

4.1.2.2 Knowledge of ISO/IEC 15408-1

Every evaluator shall be able to demonstrate knowledge about the topics required to fulfil their role according to their competence level and on which the person is authorized to work.

Every evaluator's knowledge shall include:

- a) the general model for the ISO/IEC 15408 series given in ISO/IEC 15408-1.

When the evaluator's role and competency level demand it, their knowledge shall include the following relevant items:

- b) tailoring security requirements: operations, dependencies between components and extended components;
- c) specification of protection profiles, modules, configurations and packages;
- d) handling of evaluation results;
- e) specification of security targets;
- f) composition models;
- g) multi-assurance approach; and
- h) modularization concepts.

4.1.2.3 Knowledge of ISO/IEC 15408-2

Every evaluator shall be able to demonstrate knowledge about the security functional requirements (SFRs) of ISO/IEC 15408-2 required to fulfil their role according to their competence level and the technology types on which the evaluator is authorized to work, as well as any dependent SFRs. Examples of the knowledge required by ISO/IEC 15408-2 are given in [Annex C](#).

If the evaluator is required to demonstrate competence in ISO/IEC 15408-2, then knowledge of the respective security functional requirements shall be demonstrated.

5) Under preparation. Stage at the time of publication: ISO/IEC FDIS 15408-1:2025.

6) Under preparation. Stage at the time of publication: ISO/IEC DIS 15408-2:2025.

7) Under preparation. Stage at the time of publication: ISO/IEC DIS 15408-3:2025.

8) Under preparation. Stage at the time of publication: ISO/IEC FDIS 18045:2025.

4.1.2.4 Knowledge of ISO/IEC 15408-3

Every evaluator shall be able to demonstrate knowledge about the security assurance requirements (SARs) given in ISO/IEC 15408-3 required to fulfil their role according to their competence level and that are specified by Security Targets (ST) on which the evaluator is authorized to work. The knowledge of particular SAR components shall include those on which the evaluator is authorized to work. Examples of the knowledge required by ISO/IEC 15408-3 are given in [Annex B](#).

If the evaluator is required to demonstrate competence in ISO/IEC 15408-3, then knowledge of the respective security assurance requirements shall be demonstrated.

4.1.2.5 Knowledge of ISO/IEC 15408-4

If the evaluator is required to demonstrate competence in ISO/IEC 15408-4, then the following shall be demonstrated:

- a) the framework used for deriving evaluation activities from work units in ISO/IEC 18045;
- b) the general model of evaluation methods and evaluation activities; and
- c) defining evaluation activities for extended SARs.

4.1.2.6 Knowledge of ISO/IEC 15408-5

If the evaluator is required to demonstrate competence in ISO/IEC 15408-5, then knowledge about the packages specified in ISO/IEC 15408-5 shall be demonstrated.

4.1.2.7 Knowledge of ISO/IEC 18045

Every evaluator shall demonstrate:

- a) the evaluation process, as described in ISO/IEC 18045:—, Clause 8; and
- b) security evaluation method and activities given in ISO/IEC 18045.

Additionally, every evaluator shall have the necessary knowledge required by the evaluation methods and activities specified for the assurance classes on which the person is authorized to work. Examples of the knowledge required by ISO/IEC 18045 are given in [Annex B](#).

Every evaluator working in the ALC class shall additionally have the following knowledge:

- c) site security (including physical, technical, organisational and personnel security requirements and measures, IT logical security/network security);
- d) site audits;
- e) secure development processes;
- f) software/hardware bill of materials;
- g) configuration management and development practices;
- h) information security standards; and
- i) methods for product development and its life cycle.

NOTE The class ALC is defined in ISO/IEC 15408-3.

4.1.3 Knowledge of the assurance paradigm

4.1.3.1 Knowledge of the evaluation scheme and overall evaluation framework

Evaluation schemes usually specify an overall evaluation framework with scheme-specific scope, regulations and application rules. Organizations implementing such an evaluation scheme as well as review bodies working within such an evaluation scheme typically define specifications based on the scheme. Within the predefined limits they also define their operational framework such as policies and procedures that are specific to the evaluation scheme.

Every evaluator shall be able to demonstrate knowledge of the evaluation schemes as required to fulfil their role according to their competence level. Applicable evaluation schemes are those in which the person is authorized to work.

Every evaluator shall have the necessary knowledge of the following items that are of relevance to the evaluation-related work on which the evaluator is authorized to work:

- a) scope of the evaluation scheme;
- b) any (sector-specific) regulations, legislation, policies, and further specifics;
- c) different types of evaluation/review procedures (e.g. initial review, assurance continuity as re-review, re-assessment, maintenance);
- d) guidance for organizations implementing evaluation schemes and to their evaluators;
- e) recognition arrangements;
- f) vulnerability disclosure and handling;
- g) scope of the implementing organization;
- h) policies regarding evaluation projects including entry criteria, time limits and site visit requirements;
- i) specific supporting documents;
- j) specific interpretations;
- k) specific guidance for evaluators;
- l) approved protection profiles and their supporting documents;
- m) specific assurance methods;
- n) reporting requirements;
- o) quality; and
- p) laboratory approval requirements.

NOTE See ISO/IEC 18045:—, A.5 for guidance on evaluation schemes on this topic.

4.1.3.2 Knowledge of the review body

Every evaluator shall be able to demonstrate knowledge of the review bodies, in order to fulfil their role according to their competence level. The applicable review bodies are those for which the person is authorized to work.

NOTE A review body is called an "evaluation authority" in ISO/IEC 15408-1.

EXAMPLE The Common Criteria Recognition Arrangement (CCRA) and the Senior Officials Group Information Systems Security (SOG-IS) are mutual recognition arrangements under which several evaluation schemes with their certification bodies for Common Criteria certification work. The European Union Common Criteria Scheme (EUCC) is an evaluation scheme itself with several assigned certification bodies.

IS/ISO/IEC 19896-3 : 2025

Every evaluator shall have the necessary knowledge of the following items that are of relevance to the evaluation-related work on which the evaluator is authorized to work:

- a) scope of the review body;
- b) different types of evaluation/review procedures (e.g. initial review, assurance continuity as re-review, re-assessment, maintenance);
- c) review body policies;
- d) policies regarding to evaluation projects including entry criteria, time limits and site visit requirements;
- e) specific interpretations;
- f) specific supporting documents;
- g) specific guidance;
- h) specific assurance methods;
- i) reporting requirements;
- j) vulnerability disclosure and handling; and
- k) quality.

4.1.3.3 Knowledge of the laboratory and its management system

Every evaluator shall have the necessary knowledge of the following items in order to fulfil their role and in accordance with the requirements of the evaluation scheme:

- a) the laboratory's management system, including policies, processes and procedures that are applicable to evaluators;
- b) laboratory approved methods; and
- c) laboratory competence requirements.

NOTE Management systems vary greatly in their implementations. However, items such as document control, record control, control of nonconforming testing and calibration work, handling of technical records, and conflict of interest are often the direct responsibility of every evaluator. Most laboratory management systems are based on ISO/IEC 17025.

4.1.4 Knowledge of information security

Every evaluator shall have the necessary knowledge of the following concepts in order to fulfil their role and in accordance with the requirements of the evaluation scheme:

- a) security principles;
- b) security properties;
- c) mechanisms of attack;
- d) attack potential;
- e) cryptography;
- f) secure development lifecycles;
- g) security testing;
- h) vulnerabilities and weaknesses; and

i) information security state-of-the-art concepts and technologies.

See 4.1.5 for further details on the information security topics outlined in a) to i) above, with which evaluators are expected to be familiar.

4.1.5 Knowledge of the technology

4.1.5.1 Knowledge of technology types

The ISO/IEC 15408 series and ISO/IEC 18045 can be used in the evaluation of a wide variety of information technologies. These technologies are often classified into various technology types by organizations implementing evaluation schemes, review bodies or others.

Every evaluator shall have the necessary knowledge of the information technology types on which the evaluators are authorized to work, including the common security architectures deployed for that technology type.

NOTE [Annex A](#) provides an informative list of knowledge topics presented by commonly identified technology types.

EXAMPLE Commonly identified technology types include:

- authenticator devices, access control devices and systems;
- encryption, key management and public key infrastructures (PKI) systems, products for digital signatures;
- databases;
- operating systems;
- network and network-related devices and systems;
- mobile devices and systems;
- multi-function devices;
- ICs, smart-cards and smart-card related devices and systems;
- hardware devices;
- detection devices and systems; and
- data protection, biometric systems and devices, trusted computing.

4.1.5.2 Knowledge of protection profiles, packages and supporting documents

Every evaluator shall have the necessary knowledge of the following, where applicable for the information technology on which the evaluator is authorized to work:

- a) protection profiles, functional packages, assurance packages, PP-Modules, PP-Configurations and any related supporting documents specified in connection with the evaluator's work;
- b) any additional evaluation methods and assurance activities specified as applicable to an evaluation; and
- c) how to determine if any interpretations or guidance in regard to protection profiles, packages and related supporting documents have been issued and whether they are applicable to a particular evaluation project.

Additionally, they may have knowledge of:

- d) documents that are specific to certain schemes; and

EXAMPLE 1 The EUCC documents for "IC, smartcards and similar devices" and "hardware devices with security boxes" technical domains.

- e) the cPP concept and specific cPPs.

EXAMPLE 2 cPPs for network security and operation system security.

4.1.5.3 Knowledge of specific technology

Since technology can vary and are continually evolving, it is not possible to identify all the knowledge required. [Annex A](#) provides a list of examples of both knowledge and skills for many technologies. Additional general guidance is provided in References [23] and [46], and examples for sector-specific guidance can be found in References [1],[5],[6] and [13].

Guidance on how to gain, maintain and update technology-related knowledge is provided in [A.3](#).

4.1.5.4 Knowledge for the evaluation of protection profiles, PP-Modules and PP-Configurations (classes APE and ACE)

Every evaluator evaluating protection profiles (PP) shall have additional knowledge, including the following:

- a) knowledge of the TOE's intended usage, surrounding system and processes, threat model, security objectives and provided security functionality;
- b) extensive knowledge of the relevant product type;
- c) specific knowledge of the technology used in the product type used in the PP, including the possibilities (and limitations) of this technology;
- d) knowledge on the operating environment of the product type;
- e) knowledge of the lifecycle of the product type;
- f) knowledge about modularization concepts like packages, modular PPs, conformance claims on other PPs, multi-assurance;
- g) knowledge of other PPs from the same domain;
- h) in depth knowledge of ISO/IEC 15408-2;
- i) knowledge of relevant cryptographic catalogues and standards; and
- j) modelling of algorithms, protocols and management functionality.

4.2 Knowledge required for reviewers

4.2.1 General

[4.2.2](#) to [4.2.5](#) address the knowledge that is required to review according to the ISO/IEC 15408 series and ISO/IEC 18045.

Some knowledge is required for every reviewer independent of their specific task, while other knowledge is required only depending on the specific review task and the TOE to which the reviewer is assigned.

NOTE The elements of knowledge that are required for competence can be enhanced by the previous experience gained through tasks related to the use of the ISO/IEC 15408 series and related documents. These tasks can include performing related work such as evaluation, consultancy, product development, research and specification of requirements.

4.2.2 Knowledge of the ISO/IEC 15408 series and ISO/IEC 18045

4.2.2.1 Generic knowledge of the ISO/IEC 15408 series and ISO/IEC 18045

Every reviewer's knowledge shall include:

- a) the terms and definitions defined in ISO/IEC 15408-1:—, Clause 3, ISO/IEC 15408-2:—, Clause 3 and ISO/IEC 15408-3:—, Clause 3 ;
- b) the terms and definitions defined in ISO/IEC 18045:—, Clause 3; and
- c) the context for evaluations of the ISO/IEC 15408 series.

4.2.2.2 Knowledge of ISO/IEC 15408-1

Every reviewer shall be able to demonstrate knowledge about the topics required to fulfil their role according to their competence level.

Every reviewer's knowledge shall include:

- a) the general model for the ISO/IEC 15408 series given in ISO/IEC 15408-1;
- b) tailoring security requirements: operations, dependencies between components and extended components;
- c) handling of review results;
- d) the specification of security targets;

When the reviewer's role and competency level demand it, their knowledge shall include some of the following:

- e) specification of protection profiles, modules, configurations and packages;
- f) composition models;
- g) multi-assurance-approach; and
- h) modularization concepts.

4.2.2.3 Knowledge of ISO/IEC 15408-2

Every reviewer shall be able to demonstrate knowledge about the security functional requirements (SFRs) of ISO/IEC 15408-2 required to fulfil their role according to their competence level and the technology types on which the reviewer is authorized to work, as well as any dependent SFRs. Examples of the knowledge required by ISO/IEC 15408-2 are given in [Annex C](#).

If the reviewer is required to demonstrate competence in ISO/IEC 15408-2, then knowledge of the respective security functional requirements shall be demonstrated.

4.2.2.4 Knowledge of ISO/IEC 15408-3

Every reviewer shall be able to demonstrate knowledge about the security assurance requirements (SARs) given in ISO/IEC 15408-3 required to fulfil their role according to their competence level and as specified by Security Targets (ST) on which the reviewer is authorized to work. Examples of the knowledge required by ISO/IEC 15408-3 are given in [Annex B](#).

If the reviewer is required to demonstrate competence in ISO/IEC 15408-3, then knowledge of the respective security assurance requirements shall be demonstrated.

4.2.2.5 Knowledge of ISO/IEC 15408-4

If the reviewer is required to demonstrate competence in ISO/IEC 15408-4, then knowledge of the following shall be demonstrated:

- a) the framework used for deriving evaluation activities from work units in ISO/IEC 18045;
- b) the general model of evaluation methods and evaluation activities; and
- c) the capability to define evaluation activities for extended SARs.

4.2.2.6 Knowledge of ISO/IEC 15408-5

If the reviewer is required to demonstrate competence in ISO/IEC 15408-5, then knowledge about the packages specified in ISO/IEC 15408-5 shall be demonstrated.

4.2.2.7 Knowledge of ISO/IEC 18045

Every reviewer shall demonstrate knowledge about the evaluation process described in ISO/IEC 18045: —, Clause 8.

Additionally, every reviewer shall have the necessary knowledge required by the evaluation methods and activities specified for the assurance classes on which the person is authorized to work. Examples of the knowledge required by ISO/IEC 18045 are given in [Annex B](#).

Every reviewer authorized to work in the ALC class shall additionally have knowledge of the following:

- a) site security (including physical, technical, organizational and personnel security requirements and measures, IT logical security/network security);
- b) site audits;
- c) secure development processes;
- d) software/hardware bill of materials;
- e) configuration management and development practices;
- f) information security standards; and
- g) methods for product development and its lifecycle.

4.2.3 Knowledge of the assurance paradigm

4.2.3.1 Knowledge of the evaluation scheme and overall evaluation framework

Evaluation schemes usually specify an overall evaluation framework with a scheme-specific scope, regulations and application rules. Organizations implementing such an evaluation scheme as well as review bodies working within such evaluation scheme typically define specifications based on that scheme. Within the predefined limits, they also define their operational framework such as policies and procedures that are specific to the evaluation scheme and the review body.

Every reviewer shall be able to demonstrate knowledge about the evaluation schemes required to fulfil their role according to their competence level. The applicable evaluation schemes are those to which their review body is assigned.

Every reviewer shall have the necessary knowledge of the following items that are of relevance to the review-related work on which the reviewers are authorized to work:

- a) scope of the evaluation scheme;
- b) any (sector-specific) regulations, legislation, policies, and further specifics;

- c) different types of evaluation/review procedures (e.g. initial review, assurance continuity as re-review, re-assessment, maintenance);
- d) guidance for review bodies working within the evaluation schemes and their reviewers;
- e) recognition arrangements;
- f) vulnerability disclosure and handling;
- g) scope of the implementing organization;
- h) policies regarding evaluation projects including entry criteria, time limits and site visit requirements;
- i) specific supporting documents;
- j) specific interpretations;
- k) specific guidance for reviewers;
- l) approved protection profiles and their supporting documents;
- m) specific assurance methods;
- n) reporting requirements; and
- o) quality.

NOTE See ISO/IEC 18045:—, A.5 for guidance on evaluation schemes on this topic.

4.2.3.2 Knowledge of the review body

Every reviewer shall be able to demonstrate knowledge about the review bodies, in order to fulfil their role according to their competence level. The applicable review bodies are those for which the person is authorized to work.

NOTE A review body is called an “evaluation authority” in ISO/IEC 15408-1.

EXAMPLE The “Common Criteria Recognition Arrangement (CCRA)” and the “Senior Officials Group Information Systems Security (SOG-IS)” are mutual recognition arrangements under which several evaluation schemes with their certification bodies for Common Criteria certification work. The “EU Common Criteria Scheme (EUCC)” is an evaluation scheme itself with several assigned certification bodies.

Every reviewer shall have the necessary knowledge of the following items that are of relevance to the review-related work on which the reviewer is authorized to work:

- a) scope of the review body;
- b) different types of evaluation/review procedures (e.g. initial review, assurance continuity as re-review, re-assessment, maintenance);
- c) review body policies;
- d) policies regarding evaluation projects including entry criteria, time limits and site visit requirements;
- e) specific interpretations;
- f) specific supporting documents;
- g) specific guidance;
- h) specific assurance methods;
- i) reporting requirements;
- j) vulnerability disclosure and handling; and

k) quality.

4.2.3.3 Knowledge of the review body and its management system

Every reviewer of the review body shall have knowledge of:

- a) the review body's management system, including policies, processes and procedures that are applicable to reviewers and their review activities;
- b) the review body competence requirements;
- c) structure and relevance of review criteria and evaluation methodology applied;
- d) structure and relevance of technical and organizational aspects of the evaluation and review process; and
- e) role and placement of the review body within the evaluation scheme and overall evaluation framework.

EXAMPLE The following are examples of a) to e) above:

- any sector-specific policies, regulations and legislation;
- the review body's approval requirements for the organization implementing the evaluation scheme;
- policies of organizations implementing the evaluation scheme in regard to evaluation projects including entry criteria, time limits, report requirements and site visit requirements;
- guidance for evaluators;
- specific interpretations of the organizations implementing the evaluation scheme;
- specific guidance of the organizations implementing the evaluation scheme;
- approved protection profiles and their supporting documents;
- assurance methods and activities specific to the organizations implementing the evaluation scheme; and
- reporting requirements.

NOTE 1 See ISO/IEC 18045:—, A.5 for guidance on evaluation schemes on this topic.

NOTE 2 Management systems vary greatly in their implementations. However, items such as document control, record control, handling of technical records, and conflict of interest are often the direct responsibility of every reviewer. Most review body management systems are based on ISO/IEC 17065.

4.2.4 Knowledge of information security

Every reviewer shall have general knowledge of:

- a) security principles;

EXAMPLE 1 Confidentiality, integrity and availability.

- b) security properties;

EXAMPLE 2 Security by design, security by default and data minimization.

- c) mechanisms of attack;
- d) attack potential;
- e) cryptography;
- f) secure development lifecycles;
- g) security testing;

- h) vulnerabilities and weaknesses; and
- i) information-security state-of-the-art concepts and technologies.

See [4.2.5](#) for further specific details on information security topics outlined in a) to i), with which reviewers are expected to be familiar.

4.2.5 Knowledge of technology

4.2.5.1 Knowledge of technology types

The ISO/IEC 15408 series and ISO/IEC 18045 can be used in the review of a wide variety of information technologies. These technologies are often classified into various technology types by organizations implementing evaluation schemes, review bodies or others.

Every reviewer shall have the necessary knowledge of the information technology types on which the person is authorized to review, including the common security architectures deployed for that technology type.

NOTE [Annex A](#) provides an informative list of knowledge topics presented by commonly identified technology types.

EXAMPLE Commonly identified technology types include:

- access control devices and systems;
- encryption, key management and public key information (PKI) systems, products for digital signatures;
- databases;
- operating systems;
- network and network-related devices and systems;
- mobile devices and systems;
- multi-function devices;
- ICs, smart-cards and smart-card related devices and systems;
- hardware devices;
- detection devices and systems; and
- data protection, biometric systems and devices, trusted computing.

4.2.5.2 Knowledge of protection profiles, packages and supporting documents

Every reviewer shall have the necessary knowledge of the following, where they are applicable for the information technology on which the person is authorized to review:

- a) protection profiles, functional packages, assurance packages, PP-Modules, PP-Configurations and any related supporting documents specified in connection with the reviewer's work;
- b) any additional evaluation methods and assurance which are to review;
- c) how to determine if any interpretations or guidance in regard to protection profiles, packages and related supporting documents have been issued and whether they are applicable to a particular review project.

Additionally, they may have knowledge of:

- d) documents that are specific to certain schemes; and

EXAMPLE 1 The EUCC documents for “IC, smartcards and similar devices” and “hardware devices with security boxes” technical domains.

- e) the cPP concept and specific cPPs.

EXAMPLE 2 cPPs for network security and operation system security.

4.2.5.3 Knowledge of specific technology

Since technology can vary and are continually evolving, it is not possible to identify all the knowledge required. [Annex A](#) provides a list of examples of both knowledge and skills for many technologies. Additional general guidance is provided in References [23] and [46], and examples for sector-specific guidance can be found in References [1], [5], [6] and [13].

Guidance on how to gain, maintain and update technology-related knowledge is provided in [A.3](#).

4.2.5.4 Knowledge for the review of protection profiles, PP-Modules and PP-Configurations (classes APE and ACE)

Every reviewer authorized to review protection profiles shall have additional knowledge. This shall include:

- a) knowledge of the product type's intended usage, surrounding system and processes, threat model, security objectives and provided security functionality;
- b) extensive knowledge of the relevant product type;
- c) specific knowledge of the technology used in the product type used in the PP, including the possibilities (and limitations) of this technology;
- d) knowledge on the operating environment of the product type;
- e) knowledge of the lifecycle of the product type;
- f) knowledge about modularization concepts like packages, modular PPs, conformance claims on other PPs, multi-assurance;
- g) knowledge of other PPs from the same domain;
- h) in depth knowledge of ISO/IEC 15408-2;
- i) knowledge of relevant cryptographic catalogues and standards; and
- j) modelling of algorithms, protocols and management functionality.

5 Skills

5.1 Skills required for evaluators

5.1.1 General

Some skills are required for every evaluator independent of their specific task, while other skills are required only depending on the specific evaluation task and the TOE to which the evaluator is assigned.

5.1.2 Basic evaluation skills

5.1.2.1 General evaluation work

Every evaluator shall have the skills to perform the following evaluation tasks:

- documentary/evidence analysis and assessment; and
- recording of evaluation activities and results.

Every evaluator shall have soft skills for communication, interaction and process management.

In addition, every evaluator shall have specific skills to perform evaluation activities, depending on the respective evaluation tasks on which the person is authorized to work, as depicted in [5.1.4](#).

Every evaluator authorized to work on a technical domain or for cPPs shall have the skills mandated by this technical domain or cPP respectively.

5.1.2.2 Evaluation tools

For all tools with which the evaluator is authorized to work, they shall be skilled in:

- a) the use of tools that are specified by the laboratory or organization implementing the evaluation scheme in support of evaluation, report generation, delivery or protection of documents and results;

EXAMPLE 1

- Encryption tools; and
- documentation tools.

- b) the use of specialized tools for certain evaluation tasks as specified by the laboratory or organizations implementing the evaluation scheme or supporting documents.

EXAMPLE 2

- Specialized mathematical tools for analysing measured data; and
- tools for verifying implementation of crypto algorithms.

5.1.3 Core evaluation skills regarding ISO/IEC 15408-3 and ISO/IEC 18045

5.1.3.1 Evaluation principles

Every evaluator shall be able to perform their work in a way that is:

- a) impartial;
- b) objective;
- c) repeatable; and
- d) reproducible.

Every evaluator shall be able to perform assigned evaluation tasks that follow defined evaluation methods and activities with accuracy.

Every evaluator shall be able to express the results of the evaluation so that the rationale for the decision and the references to the relevant documents and evidences are quickly understandable by the intended reader of the report.

5.1.3.2 Evaluation methods and activities

Every evaluator shall have skills in the core evaluation methods and activities specified in ISO/IEC 18045, protection profiles and any supporting documents with which the person is authorized to work. Additionally, when present, every evaluator shall have the skills for the evaluation methods and activities derived from work units in ISO/IEC 18045 or those newly defined for extended assurance components in the framework of ISO/IEC 15408-4.

Every evaluator shall be skilled in performing the activities, according to the specific definitions in ISO/IEC 18045:—, Clause 3:

- a) check;
- b) confirm;

IS/ISO/IEC 19896-3 : 2025

- c) demonstrate;
- d) describe;
- e) determine;
- f) ensure;
- g) be exhaustive;
- h) examine;
- i) explain;
- j) justify;
- k) prove;
- l) record;
- m) report;
- n) specify;
- o) trace; and
- p) verify.

5.1.4 Skills required for specific security assurance classes

Requirements for any assurance class/family/component from ISO/IEC 15408-3 (including any related dependencies) applied to a specific technical domain can cover:

- a) understanding (knowledge) of the concepts behind the assurance family/component and dependencies ([Annex B](#) provides some elements);
- b) skills to perform the documentary/evidence analysis and assessment including recording of evaluation activities and results as required in the work units associated with each component (internal consistency, cross-consistency, completeness, identification of potential areas of interest for the vulnerability analysis);
- c) skills to perform site inspection to analyse and assess the suitability and sufficiency of physical, technical, organizational and personnel security measures of developments sites;
- d) skills for ADV_SPM to understand, analyse, reproduce and assess formal models, formal properties, formal proofs, semi-formal demonstrations and correspondence rationales including the used modelling languages, mathematical theory, chosen parameters for modelling and verification, tools, and proof systems;
- e) skills to perform the independent vulnerability analysis;
- f) skills to define and run functional and penetration testing;
- g) skills to perform conformity analysis and testing; and
- h) skills to perform code analysis.

Every evaluator authorized to perform evaluation activities shall be able to write observation reports.

Every evaluator authorized to perform evaluation activities for the ADV class shall be able to:

- analyse implementation of cryptographic algorithms and protocols (both standardized and proprietary); and

- determine the security of the cryptographic algorithm's and protocol's use (both standardized and proprietary).

EXAMPLE Key length, masking scheme.

Every evaluator authorized to work with ATE activities shall be able to perform ATE planning and coordination (including functional and independent testing) and supervision.

Every evaluator authorized to work with AVA activities shall be able to perform AVA planning and coordination (including penetration testing) and supervision.

Every evaluator authorized to work with ALC should be able to evaluate software/hardware bill of materials.

NOTE The classes ADV_SPM, AVE, ATE, ALC etc. are defined in ISO/IEC 15408-3.

5.1.5 Skills required for specific security functional requirement classes

5.1.5.1 General

For each class on which the evaluator is authorized to work, the evaluator shall be able to:

- a) understand and test for conformance to related technological standards; and
- b) search for potential vulnerabilities and side channels.

5.1.5.2 Skills required for the FCS (Cryptographic support) Class

Every evaluator authorized to work on FCS shall be able to determine if cryptographic algorithms and protocols are implemented correctly and to identify and assess deviations of the TOE's implementation from claimed standards regards potential security issues.

5.1.6 Skills required for specific technology

Since technology can vary and is continually evolving, it is not possible to identify all the skills required. [Annex A](#) provides a list of both knowledge and skills for some technologies.

Guidance on how to gain, maintain and update technology-related skills is provided in [A.3](#).

5.2 Skill required for reviewers

5.2.1 Basic review skills

5.2.1.1 Review management

Every reviewer shall have skills on:

- a) communication, interaction and process management;
- b) management of stakeholders and acting transparently towards stakeholders (in particular developers, evaluators, reviewers of other organizations implementing evaluation schemes/authorities);
- c) planning of review procedures (including milestone plans and alignment with developer and evaluator);
- d) organizing and leading meetings (e.g. kick-off meeting, workshops); and
- e) working according to policies, processes and procedures defined by the evaluation scheme and review body (including confidentiality and quality management requirements).

IS/ISO/IEC 19896-3 : 2025

5.2.1.2 Review related tools

Every reviewer shall have skills on the use of tools for review activities (e.g. document/evidence storage and delivery, generation of review documentation, protection of documents and results).

5.2.2 Core review skills regarding ISO/IEC 15408-3 and ISO/IEC 18045

5.2.2.1 Review principles

Every reviewer shall have skills on:

- a) following the rules of impartiality, objectivity, accuracy;
- b) ensuring comparability concerning the application of the evaluation criteria, methods and activities;
- c) taking into account all relevant supporting documents and scheme interpretations; and
- d) observing if evaluators perform repeatable and reproducible evaluations,

5.2.2.2 Review activities

Every reviewer shall have skills on:

- a) evaluation mentoring and monitoring regarding technical and organizational aspects;
- b) reviewing and commenting on evaluation technical reports for all assurance classes;
- c) preparation and conduct of evaluation-related technical meetings (e.g. workshops);
- d) recording agreements with all parties involved in an evaluation;
- e) acceptance of evaluation technical reports;
- f) taking review decisions including their recording; and
- g) procedures to finalize a review, including approval of the ETR and final formal steps to create the review documentation (e.g. review report).

5.2.3 Skills required for specific security assurance classes

Every reviewer shall have skills on:

- a) understanding (knowledge) of the concepts behind the assurance family/component and its dependencies ([Annex B](#) provides some elements);
- b) valuation of the evaluator's analysis and documentary/evidence assessment as required in the work units associated with each component (valuation regards completeness, sufficiency, internal consistency, cross-consistency, identification of potential areas of interest for the vulnerability analysis);
- c) site audit planning, supervision and participation (ALC);
- d) ATE planning and coordination (including functional and independent testing) and supervision;
- e) AVA planning and coordination (including penetration testing) and supervision; and
- f) valuation and acceptance of the ATE and AVA evaluation activities performed, results achieved and related evaluator verdicts.

5.2.4 Skills required for specific security functional requirement classes

5.2.4.1 General

Every reviewer shall have skills on valuation and acceptance of the chosen test approach and the vulnerability analysis concerning the respective security functional requirement including the evaluation activities performed, results achieved and related evaluator verdicts.

5.2.4.2 Skills required for the FCS (cryptographic support) class

Every reviewer shall have skills on valuation and acceptance of crypto conformity analysis including the evaluation activities performed, results achieved and related evaluator verdicts.

5.2.5 Skills required for specific technology

Every reviewer shall have skills on taking into account all relevant technology-specific supporting documents and scheme interpretations.

Guidance on how to gain, maintain and update technology-related skills is provided in [A.3](#).

Annex A

(informative)

Technology types: knowledge and skills

A.1 Knowledge related to specific technology types

A.1.1 General

The taxonomy of technology types varies according to the needs of those entities categorizing them. The technology types presented in [A.1.2](#) to [A.1.15](#) are those that are frequently used.

NOTE Other technology types can be identified.

In general, every evaluator engaged with the evaluation of security functional requirements should understand the technology employed.

This annex lists examples of technology specific knowledge for every evaluator. The specific knowledge depends both on the exact technologies involved and the role of the evaluator within the evaluation.

The following knowledge is identified as being typically required by every evaluator working with specific technology types:

- a) PPs related to the technology type;
- b) evaluation tasks related to the technology type;
- c) technological standards related to the technology type;
- d) typical (security) functionality for this technology type;
- e) assumptions and security objectives for this technology type;
- f) architectural concepts for this technology type;
- g) design and implementation methods for this technology type;
- h) relevant programming languages and tools for this technology type;
- i) development and production processes for this technology type;
- j) known vulnerabilities and attack categories for this technology type; and
- k) generation of software/hardware bill of materials.

A.1.2 Access control devices and systems

Possible areas of knowledge are:

- a) access control methods; and
- b) authentication methods or authenticators devices.

See also References [\[51\]](#), [\[52\]](#) and [\[43\]](#).

A.1.3 Biometric systems and devices

Possible areas of knowledge are:

- a) statistical techniques; and
- b) biometric modalities.

See also References [\[24\]](#), [\[25\]](#), [\[29\]](#), [\[39\]](#), [\[55\]](#) and [\[63\]](#).

A.1.4 Data protection

Possible areas of knowledge are:

- a) databases;
- b) scanning techniques; and
- c) intrusion detection.

A.1.5 Databases

Possible areas of knowledge are:

- a) concepts of database management systems architecture; and
- b) access control methods.

See also Reference [\[49\]](#).

A.1.6 Detection devices and systems

Possible areas of knowledge are:

- a) concepts of detection devices and systems architecture; and
- b) concepts of pattern recognition.

A.1.7 ICs, smart-cards and smart-card related devices and systems

Possible areas of knowledge are:

- a) concepts of smart-card architecture;
- b) smart-card readers and their drivers;
- c) integrated circuits and system on chip;
- d) crypto co-processors;
- e) secure key storage;
- f) wired/wireless interfaces;
- g) physical true random bit generator;
- h) concepts of tamper proofing, resistance, detection, evidence, response;
- i) fault injection;
- j) side channel analysis; and
- k) software attacks.

See also References [\[28\]](#), [\[45\]](#) and [\[56\]](#).

IS/ISO/IEC 19896-3 : 2025

A.1.8 Hardware devices

Possible areas of knowledge are:

- a) physical security;
- b) concepts of tamper proofing, resistance, detection, evidence, response;
- c) fault injection; and
- d) side channel analysis.

See also Reference [\[40\]](#).

A.1.9 Key management systems

Possible areas of knowledge are:

- a) key management methods and techniques;
- b) random number generation;
- c) concepts of entropy;
- d) key generation;
- e) key establishment;
- f) key entry and output;
- g) key storage;
- h) key zeroization; and
- i) key transport.

A.1.10 Mobile devices and systems

Possible areas of knowledge are:

- a) concepts of mobile device architecture; and
- b) concepts of mobile device management.

See also References [\[41\]](#) and [\[50\]](#).

A.1.11 Multi-function devices

A possible area of knowledge is:

- a) concepts of multi-function device architecture.

See also References [\[53\]](#) and [\[42\]](#).

A.1.12 Network and network-related devices and systems

Possible areas of knowledge are:

- a) network architectures and topologies; and
- b) commonly used network protocols.

See also References [\[34\]](#), [\[60\]](#) and [\[61\]](#).

A.1.13 Operating systems

Possible areas of knowledge are:

- a) secure boot;
- b) protection rings;
- c) memory management;
- d) least privilege principle;
- e) access control mechanisms;
- f) principles of virtualization;
- g) separation; and
- h) random bit generation.

See also Reference [\[62\]](#).

A.1.14 Products for digital signatures

Possible areas of knowledge are:

- a) digital signature technologies;
- b) public key infrastructures (PKI);
- c) certificate authorities (CA); and
- d) key generation algorithms.

EXAMPLE Rivest-Shamir-Adleman (RSA), extended Merkle signature scheme (XMSS), Leighton-Micali Signature (LMS) and Elliptic Curve Digital Signature Algorithm (ECDSA).

See also References [\[7\]](#), [\[18\]](#) and [\[27\]](#).

A.1.15 Trusted computing

Possible areas of knowledge are:

- a) key trusted computing technology concepts:
 - 1) trusted platform module keys such as endorsement key (EK) and storage root key (SRK);
 - 2) platform configuration registers;
 - 3) secure input and output;
 - 4) memory curtaining;
 - 5) sealed storage; and
 - 6) remote attestation.

See also References [\[3\]](#), [\[47\]](#), [\[48\]](#) and [\[65\]](#).

A.2 Skills related to specific technology types

A.2.1 General

When considering the skills required for certain technology types, the specific skills required are mostly related to ATE (testing) for that technology type. These skills build upon the basic skills defined in [5.1.5](#) and [5.1.6](#) of this document.

This annex lists examples of technology specific skills for every evaluator. The specific skills depend both on the exact technologies involved and the role of the evaluator within the evaluation.

The following skills are identified as required by every evaluator working with specific technology types:

- a) the performance of evaluation methods and activities associated with the technology type; and
- b) ability to understand related technological standards.

A.2.2 Access control devices and systems

Possible areas of skills are:

- a) ability to install access control devices and systems; and
- b) ability to assess authentication functionality and protocols.

A.2.3 Biometric systems and devices

A possible area of skills is:

- a) use of statistical techniques.

A.2.4 Data protection

A possible area of skills is:

- a) ability to install access control devices and systems.

A.2.5 Databases

Possible areas of skills are:

- a) ability to correctly configure the database management system (DBMS) platforms; and
- b) ability to use structured query language (SQL) or other database query languages.

A.2.6 Detection devices and systems

A possible area of skills is:

- a) ability to install and configure detection devices and systems.

A.2.7 ICs, smart-cards and smart-card-related devices and systems

Possible areas of skills are:

- a) ability to install smart-card readers and their drivers on test platforms;
- b) ability to prepare integrated circuits for testing;

EXAMPLE 1 The use of probes.

- c) ability to configure and use electronics testing equipment;

EXAMPLE 2 Oscilloscopes, protocol analyser.

- d) ability to configure and use emulators and simulators;
- e) use of physical security techniques for penetration testing; and
- f) ability to initiate and perform penetration testing (considering invasive attacks, non-invasive attacks etc.).

A.2.8 Hardware devices

Possible areas of skills are:

- a) use of physical security techniques for penetration testing;
- b) ability to initiate and perform side-channel attacks;
- c) ability to configure and use electronics testing equipment; and

EXAMPLE Oscilloscopes, protocol analysers.

- d) ability to configure and use emulators and simulators.

A.2.9 Key Management systems

No specialized skills for this technology type have been identified.

A.2.10 Mobile devices and systems

No specialized skills for this technology type have been identified.

A.2.11 Multi-function devices

No specialized skills for this technology type have been identified.

A.2.12 Network and network-related devices and systems

No specialized skills for this technology type have been identified.

A.2.13 Operating systems

A possible area of skills is:

- a) ability to identify an operating system's TOE security function interface (TSFI).

A.2.14 Products for digital signatures

No specialized skills for this technology type have been identified.

A.2.15 Trusted computing

No specialized skills for this technology type have been identified.

A.3 Possible approaches and methods for the development of knowledge and skills

Overall knowledge and skills for evaluators and reviewers as required and outlined in [Clauses 4](#) and [5](#) can be obtained, maintained and updated through gaining corresponding expertise and experience related to evaluation and review according to Common Criteria. Such expertise and experience can be developed by repeatedly:

- a) receiving internal and external education and skill-training related to Common Criteria evaluation and review;

IS/ISO/IEC 19896-3 : 2025

- b) (self-) studying the Common Criteria and related methodology documentation, e.g. supporting documents;
- c) (self-) studying documentation related to evaluation schemes/review bodies;
- d) participating in conferences related to Common Criteria evaluation and review;
- e) working alongside and in collaboration with experienced evaluators and/or reviewers for collecting practical experience via review procedures; and
- f) (actively) participating in Common Criteria methodology related communities and their (technical) working groups.

Technology-related specific knowledge and skills for evaluators and reviewers can be obtained, maintained and updated through gaining expertise and experience with that technology. Such specific expertise and experience can be developed by continuously:

- g) receiving technology-related internal/external education and skill-training;
- h) (self-) studying relevant specialist literature;
- i) participating in specialist conferences;
- j) working alongside and in collaboration with either experienced evaluators, reviewers, or both, to collect practical experience via review procedures;
- k) exchanging information on technology aspects between evaluators, reviewers and developers;
- l) working in the development of the technology;
- m) participating in technology-related communities and their technical working groups; and
- n) performing research on the technology.

The development of overall and technology-related knowledge and skills can be supported by corresponding initial and continuing training plans (including their monitoring) managed by either the evaluation schemes, review bodies, or both.

Annex B (informative)

Examples of knowledge and skills required for evaluating security assurance requirement classes

B.1 General

This annex contains examples of the knowledge and skills required by every evaluator for the evaluation of the security assurance requirement classes given in ISO/IEC 15408-3. The examples are based on the evaluation methodology given in ISO/IEC 18045.

Within each family, the skills required increase both in depth and width. The additional skills are listed in higher members of the family. Although the increased depth of the skills is not explicitly mentioned, it shall be considered when authorizing evaluators.

EXAMPLE 1 An evaluator who is authorized to evaluate ADV_FSP.2 is expected to be able to check tracing links of the SFRs before obtaining authorization for ADV_FSP.3.

EXAMPLE 2 For ADV_TDS.1, only basic skills regarding TOE architecture are required, while for ADV_TDS.6, skills to handle formal methods for the architecture are required.

The examples given also apply to all assurance components which are hierarchically higher.

B.2 Knowledge required for specific assurance classes

B.2.1 ADV (development) class

Every evaluator performing evaluation activities related to the ADV class should have the knowledge identified in [Table B.1](#), up to and including the level of detail of the assurance components in their assigned area of evaluation responsibility. Some cells have been intentionally left blank to indicate that there is no relevant knowledge or skill for that assurance component.

Table B.1 — Example knowledge and skills required for ADV class evaluators

Assurance component	Knowledge	Skills
ADV_ARC.1	a) Self-protection property; b) Domain separation property; c) Non-bypassability property; d) Secure architecture and design concepts.	a) Ability to cross-check architectural information with other evidence provided for the evaluation.
ADV_FSP.1	a) Concept of an interface; b) Concept of SFR-supporting and SFR-enforcing TSFI; c) Methods of the specification of program interfaces;	a) Ability to identify program and application interfaces; b) Ability to determine the TSFIs;
ADV_FSP.2	d) Security architecture; e) Error messages;	
ADV_FSP.3	f) Parameters;	c) Ability to check tracing links of the SFRs;

Table B.1 (*continued*)

Assurance component	Knowledge	Skills
ADV_FSP.4		
ADV_FSP.5	g) Formal security policy model; h) Semiformal style; i) A standardized format with a well-defined syntax; j) Structured presentation methods (pseudo-code, flow charts, block diagrams).	d) Ability to understand semi-formal language;
ADV_FSP.6		e) Ability to understand formal language; f) Ability to verify the correctness of the formal model and also the completeness of the reasoning.
ADV_IMP.1	a) Sampling techniques; b) Source code languages or hardware diagram specification or IC hardware design language code or layout data used in implementing the TOE; c) Shrouding or obfuscation techniques; d) Compilers;	a) Use of sampling techniques; b) Ability to read and understand source code or hardware diagrams and/or IC hardware design language code or layout data used in implementing the TOE; c) Ability to use tools allowing for unshrouding or de-obfuscation; d) Ability to understand generation tools, their usage, and their effects. EXAMPLE Compiler configurations.
ADV_IMP.2	e) Guidance provided by the organization implementing the evaluation scheme; f) Techniques of generating TSF from an implementation representation (e.g. compilers, interpreters).	
ADV_INT.1	a) Internal structuring; b) Complexity.	
ADV_INT.2		a) Ability to identify standards relevant to the TSF in order to determine if the TSF is well-structured;
ADV_INT.3		b) Ability to judge the complexity of the TSF internals.

Table B.1 (continued)

Assurance component	Knowledge	Skills
ADV_SPM.1	a) Formal model; b) Formal properties; c) Correspondence rationale between the formal model and the functional specification; d) Semi-formal demonstration of correspondence between the formal model and any semi-formal functional specification; e) Formal proof of correspondence between the formal model and any formal functional specification; f) Well-founded mathematical theory; g) Rationale for the modelling and verification choices; h) Documentation and rationale of the tool's suitability and trustworthiness.	a) Ability to understand, analyse, reproduce and assess formal models, formal properties, formal proofs, semi-formal demonstrations and correspondence rationales; b) Ability to understand the used modelling languages, mathematical theory and chosen parameters for modelling and verification; c) Ability to use corresponding tools and proof systems.
ADV_TDS.1	a) Levels of decomposition; b) Subsystem concepts and description including categorization, purpose, behaviour, interactions, interfaces; c) Module concepts and description including categorization, purpose, behaviour, interactions, interfaces; d) Concepts of SFR-enforcing, SFR-supporting and SFR-non-interfering;	a) Ability to understand the architecture of the TOE.
ADV_TDS.2		
ADV_TDS.3		
ADV_TDS.4		
ADV_TDS.5	e) Semiformal design description;	
ADV_TDS.6	f) Proofs of correspondence.	
ADV_COMP.1	a) Concept of composite evaluation model according to ISO/IEC 15408-1; b) ETR for composite evaluation, ST, user guidance and report of the review body related to the composite TOE's base component; c) Design compliance justification and rationale.	a) Ability to understand the composition of the composite TOE from a base and dependent component; b) Ability to examine and confirm the design compliance rationale for its completeness, coherence, and internal consistency; c) Ability to examine and verify that the following requirements are fulfilled by the dependent component: — the requirements depicted in the base component's user guidance; — report of the certification body regarding secure usage of that base component.

See also Reference [19].

B.2.2 AGD (guidance documents) class

Every evaluator performing evaluation activities related to the AGD class should have the knowledge and skills identified in [Table B.2](#), up to and including the level of detail of the assurance components in their assigned area of evaluation responsibility.

Table B.2 — Example knowledge and skills required for AGD class evaluators

Assurance component	Knowledge	Skills
AGD.OPE.1	a) Concepts of user roles; b) Concepts of groups; c) The user-accessible functions and privileges; d) Secure operation; e) Operational environment.	a) Ability to understand if the operation of the TOE is correct and secure according to the evidence.
AGD_PRE.1	a) Delivery procedures; b) Secure installation techniques; c) Secure configuration.	a) Ability to understand that the installation is correct and secure according to the evidence.

See also Reference [\[31\]](#).

B.2.3 ALC (lifecycle support) class

Every evaluator performing evaluation activities related to the ALC class should have the knowledge and skills identified in [Table B.3](#), up to and including the level of detail of the assurance components in their assigned area of evaluation responsibility. Some cells have been intentionally left blank to indicate that there is no relevant knowledge or skill for that assurance component.

Table B.3 — Example knowledge and skills required for ALC class evaluators

Assurance component	Knowledge	Skills
ALC_CMC.1	a) Product lifecycle; b) Concepts of configuration management; c) Concepts of development security; d) Typical tools and techniques used in TOE development; e) Patching and flaw remediation processes; f) Integration and acceptance processes; g) Delivery processes; h) Build process (the process of transforming an implementation representation into the TOE); i) Concepts of configuration management; j) Commonly used configuration management systems; k) The application of configuration management, ensuring that the integrity of the TOE is preserved; l) Measures, procedures, and standards concerned with secure delivery of the TOE, ensuring that the security protection offered by the TOE is not compromised during the transfer to the user; m) Software/hardware bill of materials generation techniques;	a) Ability to observe the use of the configuration management (CM) system as described in the CM plan.
ALC_CMC.2	n) Configuration management systems security (access control);	
ALC_CMC.3	o) Concepts of a configuration management system plan;	
ALC_CMC.4	p) Configuration management acceptance procedures.	
ALC_CMC.5		
ALC_CMS.1	a) Concepts of configuration management; b) Commonly used configuration management systems.	a) Ability to understand versioning and identification schema; b) Ability to determine if configuration items are uniquely identified.
ALC_CMS.2		
ALC_CMS.3		
ALC_CMS.4		
ALC_CMS.5		
ALC_DEL.1	a) Measures, procedures, and standards concerned with secure delivery of the TOE, ensuring that the security protection offered by the TOE is not compromised during the transfer to the user site; b) Tamper techniques including tamper proofing, resistance, detection and evidence.	a) Ability to follow written delivery and installation procedures.

Table B.3 (continued)

Assurance component	Knowledge	Skills
ALC_DVS.1	a) Security measures, used to protect the development environment including: 1) Security controls; 2) Physical security; 3) Personnel security; 4) Procedural security.	a) Site visit planning; b) On-site and personnel assessment techniques; c) Ability to observe the application of security measures during development and maintenance of the TOE as described in the development security documentation; d) Ability to observe the practical application of delivery procedures as described in the delivery documentation.
ALC_DVS.2		
ALC_FLR.1	a) Methods of flaw remediation; b) Security flaw reporting in each stage of development; c) Patching and flaw remediation processes; d) Secure distribution of patches and changes;	a) Ability to understand flaw remediation processes.
ALC_FLR.2	e) Corrective action.	
ALC_FLR.3		
ALC_LCD.1	a) Development lifecycle models EXAMPLE 1) Agile; 2) Waterfall; 3) Lifecycle input and output documentation.	a) Ability to analyse the lifecycle processes presented by the developer.
ALC_LCD.2		
ALC_TDA.1		
ALC_TDA.2		
ALC_TDA.3		
ALC_TAT.1	a) Tools and techniques used in product development, including: 1) Well-defined development tools; EXAMPLE Programming languages or computer-aided design (CAD) systems. 2) Implementation standards.	a) Ability to analyse the tools and techniques presented by the developer.
ALC_TAT.2		
ALC_TAT.3		

Table B.3 (continued)

Assurance component	Knowledge	Skills
ALC_COMP	a) Concept of composite evaluation model according to ISO/IEC 15408-1; b) ETR for composite evaluation, ST, user guidance and report of the review body related to the composite TOE's base component; c) Integration of composition parts; d) Delivery procedures; e) Acceptance procedures; f) Configuration evidence.	a) Ability to understand the composition of the composite TOE from a base and dependent component; b) Ability to examine and verify that the correct version of the dependent component is installed onto/embedded into the correct version of the related base component; c) Ability to examine and verify the compatibility of the delivery procedures of the base component developer and the dependent component developer with the acceptance procedures of the composite product integrator; d) Ability to examine and verify that the requirements prescribed in the preparative guidance procedures by the base component developer and the dependent component developer are either implemented by the composite product integrator or are consistent with the composite product integrator guidance.

See also References [4], [8], [9], [15], [32], [33] and [35].

B.2.4 ASE and APE (ST and PP evaluation) classes

Every evaluator performing evaluation activities related to the ASE and APE classes should have the knowledge and skills identified in [Table B.4](#), up to and including the level of detail of the assurance components in their assigned area of evaluation responsibility. Some cells have been intentionally left blank to indicate that there is no relevant knowledge or skill for that assurance component.

Table B.4 — Example knowledge and skills required for ASE and APE class evaluators

Assurance component		Knowledge	Skills
ASE_CCL.1	APE_CCL.1	a) PP, ST, security requirement packages; b) Conformance claim; c) Direct rationale ST/PP.	a) Ability to check that the conformance claim is correct.
ASE_ECD.1	APE_ECD.1	a) Ability to review definition of an extended component for each extended security requirement; b) Ability to review demonstration of conformance or non-conformance to these elements.	a) Ability to understand that the extended components definition is correct.
ASE_INT.1	APE_INT.1	a) Multi-assurance concept.	a) Ability to understand that the introduction describes the TOE and the TOE context correctly.
ASE_OBJ.1	APE_OBJ.1	a) Operational environment.	a) Ability to determine if the security objectives adequately and completely address the security problem definition; b) Ability to determine if the security objectives are properly divided between the security objectives of the TOE and the security objectives for the TOE environment correctly, and that together they address the security problem definition.
ASE_OBJ.2	APE_OBJ.2		
ASE_REQ.1	APE_REQ.1	a) Subjects; b) Objects; c) Operations; d) Security attributes; e) External entities; f) Multi-assurance concept.	a) Ability to determine that the security requirements are clear, unambiguous and well-defined.
ASE_REQ.2	APE_REQ.2		

Table B.4 (continued)

Assurance component		Knowledge	Skills
ASE_SPD.1	APE_SPD.1	a) Security problem definition; b) Security objectives. c) Assets; d) Threats; e) Threat agent.	a) Ability to understand that the security problem definition is correct.
ASE_TSS.1	—		a) Ability to map narrative to specific SFRs.
ASE_COMP.1	—	a) Concept of composite evaluation model according to ISO/IEC 15408-1; b) ETR for composite evaluation, ST, user guidance and report of the review body related to the composite TOE's base component; c) Statement of compatibility between the composite product ST and the base component ST; d) Separation of the base component-TSF into those relevant base component-TSF being used by the composite product ST and others.	a) Ability to understand the composition of the composite TOE from a base and dependent component; b) Ability to examine the composite product ST and the base component ST for any conflicting assumptions and for compatibility of security objectives, security requirements and security functionality.

See also Reference [9].

B.2.5 ATE (Tests) class

Every evaluator performing evaluation activities related to the ATE class should have the knowledge and skills identified in [Table B.5](#), up to and including the level of detail of the assurance components in their assigned area of evaluation responsibility. Some cells have been intentionally left blank to indicate that there is no relevant knowledge or skill for that assurance component.

Table B.5 — Knowledge and skills required for ATE class evaluators

Assurance component	Knowledge	Skills
All components	a) Concept of a test plan; 1) Resources required for testing; 2) Commonly used testing tools; 3) Test prerequisites; 4) Testing environment; 5) Test steps (test scenario); 6) Expected result of tests; 7) Recording methods of actual test results; 8) Test verdict. b) Common test methods (e.g. functional specification, TOE design, module).	
ATE_COV.1	a) Concepts of test coverage.	a) Ability to understand the test coverage presented; b) Ability to understand tests and verify that the results of tests are correct.
ATE_COV.2		
ATE_COV.3		
ATE_DPT.1	a) Concepts of depth of testing and link with subsystem;	a) Ability to understand the test coverage documentation provided by the developer; b) Ability to understand testing at a subsystem level;
ATE_DPT.2	b) Concepts of depth of testing and link with module.	c) Ability to understand testing at a module level.
ATE_DPT.3		
ATE_DPT.4		
ATE_FUN.1	a) Concepts of functional testing.	a) Ability to understand the functional testing documentation provided by the developer.
ATE_FUN.2		

Table B.5 (continued)

Assurance component	Knowledge	Skills
ATE_IND.1	a) Type of interfaces (e.g. programmatic, command-line, protocol); b) Development of flaw hypotheses; c) Testing techniques; d) Black and white box testing techniques;	a) Development of a test plan; b) Development of appropriate test cases; c) Configuration of the TOE; d) Setup and configuration of the TOE environment; e) Maintaining the integrity of the test environment; f) Configuring and using test tools specified in the test plan; g) Commissioning appropriate test harnesses and test scripts. NOTE This can include the use of programming languages, scripting languages, and debug facilities.
ATE_IND.2	e) Sampling techniques; f) Development of independent test cases.	
ATE_IND.3		
ATE_COMP.1	a) Concept of composite evaluation model according to ISO/IEC 15408-1; b) ETR for composite evaluation, ST, user guidance and report of the review body related to the composite TOE's base component; c) Integration tests.	a) Ability to understand the composition of the composite TOE from a base and dependent component; b) Ability to define, set up and perform integration tests for the composite TOE; c) Refer as well to the skill requirements outlined for the standard approach in the relevant ATE assurance component.

See also References [37], [38] and [54].

B.2.6 AVA (vulnerability assessment) class

Every evaluator performing evaluation activities related to the AVA class should have the knowledge and skills identified in [Table B.6](#), up to and including the level of detail of the assurance components in their assigned area of evaluation responsibility. Some cells have been intentionally left blank to indicate that there is no relevant knowledge or skill for that assurance component.

Table B.6 — Example knowledge and skills required for AVA class evaluators

Assurance component	Knowledge	Skills
AVA_VAN.1	a) Classification of vulnerabilities; b) Attack taxonomies; c) Identification of sources of public vulnerability information; d) Penetration testing;	a) Ability to identify appropriate keywords for a vulnerability search; b) Ability to identify appropriate sources of information for publicly known vulnerabilities for a particular TOE; c) Ability to understand the evidence of vulnerabilities analysis and verify that the result of the evidence is correct; d) Ability to analyse cause and effect relationships of TOE functionality; e) Ability to identify residual vulnerabilities; f) Ability to calculate the attack potential; g) Ability to perform penetration testing;
AVA_VAN.2	e) Software/hardware bill of materials;	
AVA_VAN.3		h) Flaw hypothesis development; i) Ability to analyse the TSF implementation.
AVA_VAN.4	f) Methods, tools and techniques specific to the organization implementing the evaluation scheme.	
AVA_VAN.5		
AVA_COMP.1	a) Concept of composite evaluation model according to ISO/IEC 15408-1; b) ETR for composite evaluation, ST, user guidance and report of the review body related to the composite TOE's base component.	a) Ability to understand the composition of the composite TOE from a base and dependent component; b) Ability to perform a vulnerability analysis including penetration testing for the composite TOE according to the chosen assurance level and by re-using evaluation results already achieved for the composite TOE's base component (as outlined in the ETR for composite evaluation, ST, user guidance and report of the review body related to that base component); c) Refer as well to the skill requirements outlined for the standard approach in the relevant AVA assurance component.

See also References [26] and [64].

B.2.7 ACO (composition) class

Every evaluator performing evaluation activities related to the ACO class should have the knowledge and skills identified in [Table B.7](#), up to and including the level of detail of the assurance components in their assigned area of evaluation responsibility. Some cells have been intentionally left blank to indicate that there is no relevant knowledge or skill for that assurance component.

Table B.7 — Example knowledge and skills required for ACO class evaluators

Assurance component	Knowledge	Skills
All ACO components	a) Principles of composition; b) Types of composition; 1) Layering; 2) Network; 3) Component. c) Principles of system integration; d) Principles of reliance.	
ACO_COR.1		
ACO_DEV.1	a) Knowledge required for ADV class.	
ACO_DEV.2		
ACO_DEV.3		
ACO_REL.1	a) Component interactions; b) Concept of reliance; c) Tamper protection techniques including tamper proofing, resistance, detection and evidence; d) Interference protection techniques.	
ACO_REL.2		
ACO_CTT.1	a) Knowledge required for ATE class; b) Composed TOE testing.	a) The skills identified for the ADV_FSP class given in Table B.1 .
ACO_CTT.2		
ACO_VUL.1	a) Knowledge required for the AVA class; b) Knowledge of vulnerabilities applicable to composition; c) Information flow.	a) The skills identified for the AVA_VAN class given in Table B.6 ; b) Ability to determine if the assumptions and objectives specified for the operational environment of each component remain true for a composed TOE; c) Ability to identify vulnerabilities introduced as a result of composition; d) Ability to perform penetration testing.
ACO_VUL.2		
ACO_VUL.3		

See also References [\[30\]](#) and [\[53\]](#).

B.2.8 ACE (Protection Profile Configuration evaluation) class

No specific knowledge and skills have been identified for the ACE class.

Annex C (informative)

Examples of knowledge required for evaluating security functional requirement classes

C.1 General

This annex contains examples of the knowledge required by every evaluator for the evaluation of the security functional requirement classes given in ISO/IEC 15408-2.

C.2 Knowledge required for specific security functional requirement classes

C.2.1 FAU (security audit) class

The following knowledge can be required for this class:

- a) audit data generation;
- b) user identity;
- c) time stamps;
- d) audit data storage techniques;
- e) analysis of audit data;
- f) attacks that can be identified through audit data; and
- g) techniques for the protection of audit data.

See also Reference [\[14\]](#).

C.2.2 FCO (communication) class

The following knowledge can be required for this class:

- a) proof of origin;
- b) non-repudiation of origin; and
- c) non-repudiation of receipt.

C.2.3 FCS (cryptographic support) class

The following knowledge can be required for this class:

- a) concepts of entropy (unpredictability);
- b) concepts of randomness (random distribution);
- c) random bit generation;
- d) cryptographic algorithms;

EXAMPLE 1 Advanced Encryption Standard (AES), Elliptic-curve cryptography (ECC), Rivest-Shamir-Adleman (RSA).

- e) cryptographic protocols;

EXAMPLE 2 Transport Layer Security (TLS), Internet Protocol Security (IPSEC), Secure Shell (SSH).

- f) cryptographic key generation, key distribution, key management, and key destruction; and
- g) cryptographic operations.

See also References [2], [16], [17], [20], [22], [27] and [57]-[59].

C.2.4 FDP (user data protection) class

The following knowledge can be required for this class:

- a) access control techniques;

EXAMPLE Labelled access control, role-based access control.

- b) information flow control;
- c) internal TOE transfer;
- d) residual information protection techniques;
- e) rollback;
- f) stored data integrity;
- g) integrity monitoring;
- h) offline storage, import and export techniques; and
- i) data authentication techniques.

C.2.5 FIA (identification and authentication) class

The following knowledge can be required for this class:

- a) security attribute-based access control;
- b) subjects, objects and operations;
- c) data authentication;
- d) management of authentication failures;
- e) concepts of user attributes;
- f) user subject binding;
- g) username/password;
- h) authentication databases;

EXAMPLE Kerberos, Lightweight Directory Access Protocol (LDAP), Radius.

- i) authentication token;
- j) certificate-based authentication;
- k) biometric based identification and authentication techniques;
- l) secrets (e.g. passwords and pass-phrases, keys); and
- m) management of authentication mechanisms and rules.

C.2.6 FMT (security management) class

The following knowledge can be required for this class:

- a) management of TSF data;
- b) management of security attributes;
- c) management of TSF functions;
- d) revocation; and
- e) security management roles.

C.2.7 FPR (privacy) class

The following knowledge can be required for this class:

- a) concepts of anonymity;
- b) concepts of pseudonymity;
- c) concepts of unlinkability; and
- d) concepts of unobservability.

See also References [\[21\]](#) and [\[36\]](#).

C.2.8 FPT (protection of the TSF) class

The following knowledge can be required for this class:

- a) knowledge required for the FCS class given in [C.2.3](#);
- b) knowledge required for the FDP class given in [C.2.4](#);
- c) physical tampering techniques including tamper proofing, resistance, detection and evidence;
- d) trusted recovery techniques;
- e) replay attacks;
- f) time stamp techniques;
- g) concepts of self-tests;
- h) state synchrony;
- i) data protection; and
- j) concept of the principle of fail secure.

C.2.9 FRU (resource utilization) class

The following knowledge can be required for this class:

- a) fault tolerance techniques;
- b) priority of service techniques;
- c) resource allocation techniques; and
- d) denial of service attacks.

C.2.10 FTA (TOE access) class

The following knowledge can be required for this class:

- a) concepts of sessions: concurrent sessions;
- b) session establishment;
- c) session locking and termination; and
- d) access history.

C.2.11 FTP (trusted path/channels) class

The following knowledge can be required for this class:

- a) concept of a trusted path;
- b) concept of a trusted channel;
- c) knowledge required for the FCS class given in [C.2.3](#); and
- d) concept of a trusted third party (TTP).

Bibliography

- [1] ISO 11568 (all parts), *Financial services — Key management (retail)*
- [2] ISO/IEC 11770 (all parts), *Information security — Key management*
- [3] ISO/IEC 11889 (all parts), *Information technology — Trusted platform module library*
- [4] ISO/IEC/IEEE 12207, *Systems and software engineering — Software life cycle processes*
- [5] ISO/TS 14441, *Health informatics — Security and privacy requirements of EHR systems for use in conformity assessment*
- [6] ISO/TR 14742, *Financial services — Recommendations on cryptographic algorithms and their use*
- [7] ISO/IEC 14888 (all parts), *Information security — Digital signatures with appendix*
- [8] ISO/IEC/IEEE 15026 (all parts), *Systems and software engineering — Systems and software assurance*
- [9] ISO/IEC/TR 15446, *Information technology — Security techniques — Guidance for the production of protection profiles and security targets*
- [10] ISO/IEC 17025, *General requirements for the competence of testing and calibration laboratories*
- [11] ISO/IEC/TS 17027, *Conformity assessment — Vocabulary related to competence of persons used for certification of persons*
- [12] ISO/IEC 17065, *Conformity assessment — Requirements for bodies certifying products, processes and services*
- [13] ISO/TS 17574, *Electronic fee collection — Guidelines for security protection profiles*
- [14] ISO/IEC 18014 (all parts), *Information security — Time-stamping services*
- [15] ISO/IEC/TR 18018, *Information technology — Systems and software engineering — Guide for configuration management tool capabilities*
- [16] ISO/IEC 18032, *Information security — Prime number generation*
- [17] ISO/IEC 18033 (all parts), *Information security — Encryption algorithms*
- [18] ISO/IEC 18370 (all parts), *Information technology — Security techniques — Blind digital signatures*
- [19] ISO/IEC/TS 19249, *Information technology — Security techniques — Catalogue of architectural and design principles for secure products, systems and applications*
- [20] ISO/IEC 19592 (all parts), *Information technology — Security techniques — Secret sharing*
- [21] ISO/IEC TS 19608, *Guidance for developing security and privacy functional requirements based on ISO/IEC 15408*
- [22] ISO/IEC 19772, *Information security — Authenticated encryption*
- [23] ISO/IEC TR 19791, *Information technology — Security techniques — Security assessment of operational systems*
- [24] ISO/IEC 19792, *Information security, cybersecurity and privacy protection — General principles, requirements and guidance for security evaluation of biometric systems*
- [25] ISO/IEC 19795 (all parts), *Information technology — Biometric performance testing and reporting*

- [26] ISO/IEC TR 20004, *Information technology — Security techniques — Refining software vulnerability analysis under ISO/IEC 15408 and ISO/IEC 18045*
- [27] ISO/IEC 20008 (all parts), *Information security — Anonymous digital signatures*
- [28] ISO/IEC 24727 (all parts), *Identification cards — Integrated circuit card programming interfaces*
- [29] ISO/IEC 24745, *Information security, cybersecurity and privacy protection — Biometric information protection*
- [30] ISO/IEC/IEEE 24748-6, *Systems and software engineering — Life cycle management — Part 6: System and software integration*
- [31] ISO/IEC/IEEE 26513, *Systems and software engineering — Requirements for testers and reviewers of information for users*
- [32] ISO/IEC 27001, *Information security, cybersecurity and privacy protection — Information security management systems — Requirements*
- [33] ISO/IEC 27002, *Information security, cybersecurity and privacy protection — Information security controls*
- [34] ISO/IEC 27033 (all parts), *Information technology – Network security*
- [35] ISO/IEC 27034 (all parts), *Information technology — Application security*
- [36] ISO/IEC 29101, *Information technology — Security techniques — Privacy architecture framework*
- [37] ISO/IEC/IEEE 29119 (all parts), *Software and systems engineering — Software testing*
- [38] ISO/IEC 29128-1, *Information security, cybersecurity and privacy protection — Verification of cryptographic protocols — Part 1: Framework*
- [39] ISO/IEC 29164, *Information technology — Biometrics — Embedded BioAPI*
- [40] ISO/IEC/TS 30104, *Information Technology — Security Techniques — Physical Security Attacks, Mitigation Techniques and Security Requirements*
- [41] ISO/IEC/TR 30125, *Information technology — Biometrics used with mobile devices*
- [42] IEEE Standard 2600-2008, *Hardcopy Device and System Security*
- [43] EUROPEAN COMMISSION INFORMATION. Document ID - System Security Policy C(2006) 3602: *Standard on Access Control and Authentication*: Available at <https://www.eba.europa.eu/documents/10180/1449046/Annex+7+Standard+on+Access+Control+and+Authentication.pdf/cba4e74d-f54d-4797-9204-6dae43560e65>
- [44] NIST SP 800-130: *A Framework for Designing Cryptographic Key Management Systems*. Available at <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-130.pdf>
- [45] SENIOR OFFICIALS GROUP INFORMATION SYSTEMS SECURITY (SOGIS). *Supporting documents for smart card evaluations*: Available at https://www.sogis.eu/uk/supporting_doc_en.html
- [46] ANDERSON R.J. *Security Engineering: A Guide to Building Dependable Distributed Systems*: [ONLINE]: Wiley: Available at <https://www.cl.cam.ac.uk/~rja14/book.html>
- [47] CHALLENGER, DAVID, et al. *A Practical Guide to Trusted Computing (For TPM 1.2)*. IBM Press
- [48] CHALLENGER, DAVID, and ARTHUR, WILL. *A Practical Guide to TPM 2.0*. Apress Open
- [49] ELMARS, RAMEZ, and NAVATHE, SHAMKANT B. *Fundamentals of Database Systems*: Pearson

IS/ISO/IEC 19896-3 : 2025

- [50] FERNANDEZ-SAAVEDRA B., SANCHEZ-REILLO R., SANCHEZ-REDONDO C., BLANCO-GONZALO R. Testing of biometric systems integrated in mobile devices. *International Carnahan Conference on Security Technology (ICCST)*, 2015. IEEE.
- [51] FERRAIOLO, DAVID F.; KUHN, D. RICHARD and CHANDRAMOULI, RAMASWAMY: *Role Based Access Control*. Artech House Inc.
- [52] HU, VINCENT C.; FERRAIOLO, DAVID F., and KUHN, D. RICK: NIST IR 7316: *Assessment of Access Control Systems*: Available at <https://csrc.nist.gov/publications/nistir/7316/NISTIR-7316.pdf>
- [53] KARGER P.A., KURTH H. Increased Information Flow Needs for High-Assurance Composite Evaluations. in *Second IEEE International Information Assurance Workshop*. 8-9 April 2004, Charlotte, NC: IEEE Computer Society. p. 129-140.
- [54] PATTON, RON. *Software Testing*: Sams Publishing
- [55] PHILLIPS, P.J.; MARTIN, A.; WILSON, C.L., and PRZYBOCKI, M. An introduction to evaluating biometric systems. *Computer*, Vol33: Issue 2, Feb 2000. IEEE
- [56] RANKL, WOLFGANG, and EFFING, WOLFGANG. *Smart Card Handbook*: Wiley
- [57] RISTIC, IVAN. *Bulletproof SSL and TLS*. Feisty Duck
- [58] SCHNEIER, BRUCE. *Applied Cryptography*. Wiley
- [59] SCHNEIER, BRUCE. *Practical Cryptography*. Wiley
- [60] STALLINGS, WILLIAM. *Cryptography and Network Security: Principles and Practice*: Pearson
- [61] TANENBAUM, ANDREW, and WETHERAL, DAVID J. *Computer Networks*: Pearson
- [62] TANENBAUM, ANDREW S, and WOODHULL, ALBERT S. *Operating Systems: Design and Implementation*. Pierson/Prentice Hall
- [63] WAYMAN, JAMES; JAIN, ANIL; MALTONI, DAVIDE, and MAIO, DARIO (Editors). *Biometric Systems: Technology, Design and Performance evaluation*: Springer Verlag
- [64] MITRE. *Common Attack Pattern and Enumeration: Mechanisms of Attack*. [ONLINE]: Available at <https://capec.mitre.org/data/definitions/1000.html>
- [65] Various resources from Trusted Computing Group available at <https://trustedcomputinggroup.org/resources/>

(Continued from second cover)

<i>International Standards</i>	<i>Corresponding Indian Standard</i>	<i>Degree of Equivalence</i>
ISO/IEC 15408-1 Information security, cybersecurity and privacy protection — Evaluation criteria for IT security — Part 1: Introduction and general model	IS 14990 (Part 1) : 2024/ISO/IEC 15408-1 : 2022 Information security, cybersecurity and privacy protection — Evaluation criteria for IT security: Part 1 Introduction and general model (<i>third revision</i>)	Identical
ISO/IEC 15408-2 Information security, cybersecurity and privacy protection — Evaluation criteria for IT security— Part 2: Security functional components	IS 14990 (Part 2) : 2024/ISO/IEC 15408-2 : 2022 Information security, cybersecurity and privacy protection — Evaluation criteria for IT security: Part 2 Security functional components (<i>third revision</i>)	Identical
ISO/IEC 15408-3 Information security, cybersecurity and privacy protection — Evaluation criteria for IT security— Part 3: Security assurance components	IS 14990 (Part 3) : 2024/ISO/IEC 15408-3 : 2022 Information security, cybersecurity and privacy protection — Evaluation criteria for IT security: Part 3 Security assurance components (<i>third revision</i>)	Identical
ISO/IEC 15408-4 Information security, cybersecurity and privacy protection — Evaluation criteria for IT security — Part 4: Framework for the specification of evaluation methods and activities	IS 14990 (Part 4) : 2024/ISO/IEC 15408-4 : 2022 Information security, cybersecurity and privacy protection — Evaluation criteria for IT security: Part 4 Framework for the specification of evaluation methods and activities	Identical
ISO/IEC 15408-5 Information security, cybersecurity and privacy protection — Evaluation criteria for IT security— Part 5: Pre-defined packages of security requirements	IS 14990 (Part 5) : 2024/ISO/IEC 15408-5 : 2022 Information security, cybersecurity and privacy protection — Evaluation criteria for IT security: Part 5 Pre-defined packages of security requirements	Identical
ISO/IEC 18045 Information security, cybersecurity and privacy protection — Evaluation criteria for IT security — Methodology for IT security evaluation	IS 15671 : 2024/ISO/IEC 18045 : 2022 Information security, cybersecurity and privacy protection — Evaluation criteria for IT security — Methodology for IT security evaluation (<i>second revision</i>)	Identical

Bureau of Indian Standards

BIS is a statutory institution established under the *Bureau of Indian Standards Act, 2016* to promote harmonious development of the activities of standardization, marking and quality certification of goods and attending to connected matters in the country.

Copyright

BIS has the copyright of all its publications. No part of these publications may be reproduced in any form without the prior permission in writing of BIS. This does not preclude the free use, in the course of implementing the standard, of necessary details, such as symbols and sizes, type or grade designations. Enquiries relating to copyright be addressed to the Head (Publication & Sales), BIS.

Review of Indian Standards

Amendments are issued to standards as the need arises on the basis of comments. Standards are also reviewed periodically; a standard along with amendments is reaffirmed when such review indicates that no changes are needed; if the review indicates that changes are needed, it is taken up for revision. Users of Indian Standards should ascertain that they are in possession of the latest amendments or edition by referring to the website- www.bis.gov.in or www.standardsbis.in.

This Indian Standard has been developed from Doc No.: LITD 17 (33421).

Amendments Issued Since Publication

Amend No.	Date of Issue	Text Affected

BUREAU OF INDIAN STANDARDS

Headquarters:

Manak Bhavan, 9 Bahadur Shah Zafar Marg, New Delhi 110002

Telephones: 2323 0131, 2323 3375, 2323 9402

Website: www.bis.gov.in

Regional Offices:

	Telephones
Central : 601/A, Konnectus Tower -1, 6 th Floor, DMRC Building, Bhavbhuti Marg, New Delhi 110002	{ 2323 7617
Eastern : 8 th Floor, Plot No 7/7 & 7/8, CP Block, Sector V, Salt Lake, Kolkata, West Bengal 700091	{ 2367 0012 2320 9474
Northern : Plot No. 4-A, Sector 27-B, Madhya Marg, Chandigarh 160019	{ 265 9930
Southern : C.I.T. Campus, IV Cross Road, Taramani, Chennai 600113	{ 2254 1442 2254 1216
Western : 5 th Floor/MTNL CETTM, Technology Street, Hiranandani Gardens, Powai Mumbai 400076	{ 25700030 25702715

Branches : AHMEDABAD, BENGALURU, BHOPAL, BHUBANESHWAR, CHANDIGARH, CHENNAI, COIMBATORE, DEHRADUN, DELHI, FARIDABAD, GHAZIABAD, GUWAHATI, HARYANA (CHANDIGARH), HUBLI, HYDERABAD, JAIPUR, JAMMU, JAMSHEDPUR, KOCHI, KOLKATA, LUCKNOW, MUMBAI, NAGPUR, NOIDA, PARWANOO, PATNA, PUNE, RAIPUR, RAJKOT, SURAT, VIJAYAWADA.